

IT CONSEILS

42 Rue de la Gare

62000 Arras



Rapport d'audit Mairie de Kernelac

Monsieur le Maire,

Vous nous avez mandaté pour recenser les besoins émanant de vos services, et réaliser le constat de l'état de votre système d'information.

Nous avons le plaisir de vous communiquer le résultat des différents temps d'échanges avec vos services, mais également nos conclusions concernant l'efficacité de votre système d'information.

1. Contexte et objectifs

La mairie de Kernelac a mandaté IT Conseils pour réaliser un audit complet de son système d'information. Cet audit porte sur les volets :

- Systèmes (serveurs, postes de travail, sauvegardes)
- Réseaux (LAN, Wi-Fi, connexions Internet, VPN)
- Cybersécurité (pare-feu, antivirus, gestion des droits, sensibilisation)

L'objectif est de :

- Évaluer la conformité avec les référentiels de l'ANSSI, le RGPD, et la directive NIS2
- Identifier les vulnérabilités et proposer des recommandations correctives

2. Méthodologie

- Entretiens avec les responsables informatiques et agents municipaux
- Revue documentaire (chartes, procédures, politiques de sécurité, registre RGPD)
- Scans techniques (audit de vulnérabilités, cartographie réseau, analyse de configurations)

- Tests de conformité avec les référentiels suivants :
 - ANSSI : guides RGS, PSSI, Hygiène informatique
 - RGPD : CNIL - principes fondamentaux
 - NIS2 : exigences minimales pour les entités du secteur public

3. Résumé exécutif

L'audit met en évidence une implication forte de l'équipe municipale pour la modernisation de son SI. Toutefois, des axes de non-conformité ont été détectés, notamment :

- Une politique de sécurité formalisée mais non diffusée ni appliquée
- Des postes encore sous Windows 7, non conformes
- Une absence de gestion centralisée des journaux (logs)
- Des sauvegardes non testées régulièrement
- Une documentation RGPD incomplète (manque de registre et de DPO clairement désigné)
- Aucune cartographie réseau formelle

Des recommandations sont proposées dans la section 6.

4. État des lieux technique

4.1 Parc informatique

- Serveurs : 2 serveurs physiques, 1 hyperviseur (VMware ESXi 6.5)
- Postes utilisateurs : 35, dont 7 obsolètes (Windows 7 / Office 2010)
- Imprimantes réseau : 6
- Applications métiers : logiciel d'état civil, finances, urbanisme, cantine

4.2 Réseau

- Topologie : réseau local non segmenté, absence de VLAN
- Pare-feu : Box opérateur avec NAT, pare-feu logiciel sur les postes
- VPN : utilisé uniquement par le secrétaire général, sans MFA
- Wi-Fi : réseau invité non isolé du réseau administratif

4.3 Sauvegardes

- Sauvegardes locales sur NAS, externalisées hebdomadairement via disque USB
- Pas de tests réguliers de restauration
- Pas de plan de reprise d'activité (PRA) formalisé

5. Analyse de conformité

5.1 Conformité ANSSI (Hygiène informatique)

Élément	Statut	Observations
Politique de sécurité	Partielle	Document interne non à jour
Gestion des comptes	Non conforme	Absence de politique de mot de passe robuste
Journalisation des accès	Non conforme	Pas de centralisation ni d'analyse
Inventaire SI	Partielle	Liste manuelle non à jour
Mise à jour logicielle	Non conforme	Windows 7 encore utilisé
Segmentation réseau	Non conforme	Pas de VLAN
MFA pour accès distant	Non conforme	Accès VPN simple mot de passe

5.2 Conformité RGPD

Élément	Statut	Observations
Registre des traitements	Inexistant	Aucun registre structuré fourni
Délégué à la protection des données	Inconnu	Aucune désignation officielle
Information des usagers	Partielle	Affichage RGPD en mairie, mais non exhaustif
Analyse d'impact (PIA)	Non réalisée	Données sensibles non couvertes
Sauvegarde des données	Partielle	Pas de garantie de confidentialité ou d'intégrité

5.3 Conformité NIS2

Élément	Statut	Observations
---------	--------	--------------

Cartographie des services critiques	Inexistant	Aucun schéma ni documentation
Gestion des incidents	Non conforme	Aucune procédure formalisée
Formation à la cybersécurité	Partielle	Aucune formation récente recensée
Surveillance et journalisation	Non conforme	Absence de SIEM ou équivalent
Plan de continuité / reprise	Inexistant	Pas de PRA/PCA

6. Recommandations

Court terme (0-3 mois)

- Remplacer les postes Windows 7
- Isoler les réseaux Wi-Fi invités
- Mettre en place une politique de mot de passe conforme (longueur, rotation)
- Désigner un DPO ou externaliser la fonction
- Établir un registre RGPD

Moyen terme (3-6 mois)

- Mettre en œuvre une solution de journalisation centralisée
- Élaborer un plan de reprise d'activité
- Mettre en place une segmentation réseau (VLAN)
- Tester régulièrement les sauvegardes

Long terme (6-12 mois)

- Réaliser une cartographie complète du SI
- Mettre en place une gestion des vulnérabilités
- Organiser des sessions de sensibilisation à la cybersécurité
- Étudier la possibilité d'un hébergement dans un cloud souverain ou GIP mutualisé

7. Conclusion

L'environnement informatique de la mairie de KERNELAC montre une volonté d'équipement mais présente des lacunes critiques en matière de cybersécurité et de conformité. L'audit permet d'identifier des priorités claires à adresser dans un plan d'action triennal.

8. Annexes

- Cartographie réseau simplifiée
- Liste des équipements audités
- Fiche de vulnérabilités techniques
- Checklist ANSSI – 40 règles d'hygiène
- Fiche synthèse RGPD